DRAFT VERSION

(work in progress)

Sample-Ama Uris

Risk Assessment

Context

Imagine that you're starting a new job as a cybersecurity expert for a **tech company headquartered in South Florida**. The **headquarters is on a main boulevard near the beach**. This **building contains servers for storing backups**. **Employees use company computers** and **wifi for network access**.

Your supervisor tasks you with completing a risk assessment for the company. To start, you'll determine the risks.

TO DO: Create section in this document for Threat categories, Likelihood & Impact, Recovery ability & Risk Tolerance?. Ask Dale.

Sample-Ama Uris

Risk Identification, Impact & Tolerance

Risks *Threat categories.*	**Likelihood** *Frequency.*	**Impact** *Harm.*	**Recovery ability** *Time and external resources required to restore our system.* **Regular** *Predictable time and internal resources required (e.g., standard patch or credential reset).* **Supplemented** *Requires additional internal cross-departmental resources.* **Extended** *Requires external assistance (forensic contractors, legal counsel, vendor support) and unpredictable recovery timeline.* **Not Recoverable** *Data or systems cannot be restored*	**Risk Tolerance** *Based on Likelihood, Impact and Recovery ability.* **High** = *Low pre-incident investment in redundancy/backups.* **Low** = *High pre-incident investment in Instant Failover, High Availability (HA), Immutable Backups & automated disaster recovery)*

			(e.g., unbacked-up data destroyed)	
External				
Attackers *Unauthorised hackers try to bypass network and systems security to access data for malicious purposes.*	**High** (*External threat actors account for 80%–83% of all malicious data breaches.*)	**Operational**. System downtime during recovery, confidential data exposed/loss/corrupted, and longer recovery time due to environmental stress (storms, flooding, evacuations). **Financial**. Lost income, Disaster recovery costs, SLA fines, state and federal penalties (Florida FIPA Compliance; FTC Act; SEC Cybersecurity Disclosure Rules), and South Florida insurance crisis. **Legal**. Non-compliance with SLAs,and state and federal law. **Reputational**. Customer confidence in the company's ability to uphold confidentiality, integrity and availability (CIA triad) is temporarily in doubt.	**Extended**	**Low**
Malware *Types of malicious code - software or firmware that conducts unauthorized actions that negatively*	**Very High** *(High-value targets and supply chain access, and expanded surfaces to attack e.g. remote workforce infrastructure and*	**Operational.** Single-site operation represents a single point of failure. Recovery	**Extended** to **Not Recoverable**	**Low**

Sample-Anna Uris

affects system security.	*complex cloud environments, etc.)*	efforts are negatively affected by environmental stress and can lead to dual-disaster or extended downtime. Confidential data breach and exfiltration (data lost, corrupted, extorted or exposed). **Financial.** Disaster recovery costs, lost income, SLA fines, state and federal penalties, and South Florida insurance crisis. **Legal.** Non-compliance with agreements, state and federal law. **Reputational.** Customer confidence in product/service is damaged.		
Natural Disaster *South Florida experiences frequent tropical storms, severe thunderstorms, and lightning strikes, alongside Hurricanes.* *.*	**Extremely High** *(A single-site location of South Florida, which has the highest hurricane frequency rate in the U.S.: Every 6-8 years. Hurricanes can cause catastrophic storm surges, inland flash floods, tornadoes, landslides, and widespread infrastructure collapses).*	**Operational.** Total physical and digital infrastructure failure flatlining operations, power grid collapse, communications blackout and increased cyber vulnerabilities = threats that can lead to confidential data breaches. **Financial.** Uninsurable or unaffordable insurance premiums, high SLA penalties and **Legal.**	**Extended** to **Not Recoverable**	**Very Low**

Sample-Anna Uris

		SLA breaches and other state and federal non-compliance. **Reputational.** Customers may permanently flee to non-coastal competitors.		
Internal				
User Mistakes	**Extremely High** *(Human fatigue, social engineered phishing, cognitive overload, lack of security training, complex user interfaces, and the push for speed in engineering environments.)*	**Operational.** Defense in depth means companies build layers of containment around the user. Impact is restricted by the principle of least privilege, automated scanners and virtualization. **Financial.** state and federal penalties can result from extended system down time if mistakes happen during storm evacuations, etc. Increased cyber insurance premiums. **Legal.** Non-compliance with state and federal law if downtime extended for whatever reason. **Reputational.** Customers may view business operations as incompetent.	**Regular** to **Supplemented**	**Medium** (**Low** during environmental stress)
Malicious Insiders	**Low** to **Moderate** *(Disgruntled employees, staff facing financial hardship,*	**Operational.** Separation of duties, peer requirements,	**Extended** to **Not Recoverable**	**Very Low**

Sample-Annex-UFS

	departing workers stealing IP for a competitor, or employees coerced/bribed by organized crime syndicates.)	Immutable infrastructure and behavioral monitoring lower the operational, legal and financial impact, unless there was a confidential data breach, which makes the impact serious. **Financial.** Intellectual property theft = loss of valuation. Litigation costs for investigation, redistribution lawsuits, and affected customers of confidential data breach. **Legal.** In the event of a confidential data breach: state law penalties, federal enforcement and class-action lawsuits. **Reputational.** In the event of a confidential data breach: seen as fundamental company governance failure = customer confidence loss, investor loss and competitor exploitation.		
Equipment failure	**High** *(Due to South Florida location: environmental stress leads to frequent power grid instability and supply-chain delays. Coastal + weather conditions negatively affect hardware.)*	**Operational.** Single site = lack of geographic redundancy which can result in data availability and integrity loss. **Financial.** SLA penalties, recovery expenses and	**Extended**	**Low**

Sample-Ana Uris

		revenue loss. **Legal.** SLA/contractual breaches, and regulatory compliance audits. **Reputational.** Dropped customer confidence in reliability and technical architecture = client loss, investor loss and competitor exploitation.		
Multiparty				
Location-wide Power Outages		**Operational.** Cuts connection to the cloud = catastrophic business isolation for customers and employees and cellular backup loss due to congested cellular networks. **Financial.** Financially liable for downtime (SLA penalties), and increasing utility mitigation costs. **Legal.** A single-site setup in a known hurricane zone can be seen as negligent planning and lead to contractual breach of business continuity. Timing of outage after a security incident can also lead to non-compliance fines with state and federal laws. **Reputational.** Geo-risk liability results in loss of professional	**Extended** to **Not Recoverable**	**Very Low**

Sample-Anna Uris

		credibility.		
Internet / Service provider outages		**Operational.** Can break security automations and freeze the software ecosystem and heighten cyber vulnerabilities leading to data CIA triad loss. **Financial.** Financially liable for downtime (SLA penalties), and increasing utility mitigation costs. **Legal.** Timing of outage after a security incident can also lead to non-compliance fines with state and federal laws. **Reputational.** Single-site risk liability results in loss of professional credibility.	**Extended**	**Low**

Sample-Anna Uris